



Disclaimer: This document is provided for informational and educational purposes only as part of GRC Mastery training course. While we have made reasonable efforts to ensure the accuracy of the information contained herein, it is not intended to be professional advice. We make no warranties or representations of any kind, express or implied, regarding the accuracy or completeness of the information provided. You should not rely on this document for any commercial decision-making. By using this document, you agree to hold us harmless from any and all damages or losses arising from your use of this document.



Information Security Management System Objectives

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review



Purpose

This document outlines the information security objectives of Stark Industries Inc., established in alignment with the company's business goals and ISO/IEC 27001:2022 Clause 6.2. These objectives are measurable, monitored, communicated, and updated as needed to support continual improvement of the Information Security Management System (ISMS).

Scope

Applies to all departments, employees, contractors, and operations within the defined ISMS scope, specifically focusing on the development, deployment, and maintenance of the SaaS marketing platform.

Objectives Overview

The following objectives have been established to maintain and improve the security posture of Stark Industries Inc.:

Objective	Target	Measurement Method	Owner	Review Frequency
Ensure 100% of production deployments undergo secure code review	100% of releases	Secure code review report findings	Software Developer	Quarterly
Perform Application Penetration testing and remediate all High and Medium findings	100%	Penetration testing remediation report	Information Security Manager	Annually
Maintain uptime of SaaS platform above 99.9%	≥ 99.9% monthly	AWS monitoring reports	IT Infrastructure Engineer	Monthly



Train all staff in basic information security awareness	100% completion	Training attendance logs	Information Security Manager	Annually
Address critical vulnerabilities in production within 5 business days	≥ 95% on time	Vulnerability tracking tool	Information Security Analyst	Monthly
Complete internal ISMS audit annually	1 audit per year	Internal audit report	GRC Analyst	Annually
Keep the risk register up to date	No overdue entries > 30 days	Risk register log	GRC Analyst	Monthly
Achieve ISO 27001 Certification	Gain Certification	Certification Outcome	Information Security Manager	Annually

Objective Management

Objectives are aligned with business strategy, risk assessment outcomes, and stakeholder requirements.

Each objective is:

- Clearly defined
- Assigned to a responsible owner
- Tracked using specific KPIs or tools

Objectives are periodically reviewed in:

- Management reviews (Clause 9.3)
- Internal audits
- Risk assessments

Communication and Monitoring



Objectives are communicated internally through onboarding, training sessions, and ISMS documentation.

Performance against objectives is monitored continuously and reported during management review meetings.

GRCMastery.com